

Lean Technologies

Outsourcing Standard

Approving Authority	RCC
Prepared By	VP Infosec
Approval Date	March 2025
Next Scheduled Review	March 2026
Description	This document provides outsourcing controls and procedures for the requirements that are based upon Lean security policies and standards as well as industry standards.
Version	2.0

Contents

TABLE OF CONTENTS

1. Overview	3
1.1 Objective	3
1.2 Scope	3
1.3 Exceptions	3
1.4 Audience	3
2. Outsourcing Policy	3
2.1 Requirements	3
2.1.1 Due Diligence	3
2.1.2 Measurement and Evaluation	4

1. Overview

1.1 Objective

This document provides cyber security controls that are based upon Lean security policies and standards as well as industry standards to ensure these topics are covered while entering, during and exiting outsourcing contracts.

1.2 Scope

This applies to all outsourcing arrangements, including and not restricted to contracts with third party vendors, third party developers and contractors.

All new outsourcing relationships must be designed to comply with this standard or the Contract and Vendor Management Policy. Existing relationships must develop a remediation plan to get into compliance with this standard.

1.3 Exceptions

Where compliance cannot be met or enforced due to a third party, an exception must be filed, reviewed, and approved. The exception request must describe compensating security controls or risk acceptance. Exceptions must be submitted to the Lean Cyber Security Department.

1.4 Audience

This policy is intended exclusively for the members of the Risk and Compliance Committee (RCC), who are responsible for evaluating, managing, and ensuring compliance with cybersecurity controls, vendor security assessments, and contractual obligations. It is designed to guide RCC members in enforcing security best practices, monitoring vendor SLA adherence, and mitigating risks associated with third-party engagements.

2. Outsourcing Policy

The following outlines the security requirements for each sub area regarding the outsourcing lifecycle.

2.1 Requirements

Lean Technologies shall define, approve, implement, and communicate cyber security requirements within the outsourcing processes. These requirements shall be based on the Lean Tech's' risk appetite and the sensitivity of the information assets that the vendor will have access to.

2.1.1 Due Diligence

- Lean Tech carries out a risk assessment to identify risk related to external part access where required.
- Where possible, Lean Tech agrees with the external party which controls are required to be implemented and documents drafted by the Lean Tech legal advisors
- Controls required by Lean Tech may included the following or otherwise not listed:
 - o Data Encryption, classification and Data Loss Prevention
 - o User authentication, Multi Factor Authentication, Role Based Authentication, and Access Review
 - o Network security including Firewalls and Intrusion Detection
 - o Incident Response Plan
 - o Risk Assessments and Service Level Agreements
 - o Log Management or Event Management
 - o Disaster Recovery or Backup and Restoration
- Lean Tech may choose to select providers based on their ability to demonstrate accredited certification to the requirements of the standard or scheme provided that the scope of certification includes the services Lean tech wishes to procure.

2.1.2 Measurement and Evaluation

- Lean Tech may measure or evaluate the effectiveness of the defined controls within the policy.
- This may include but is not limited to:
 - o Vulnerability assessments
 - o Security audits
 - o Incident analysis
 - o KPIs
 - o User awareness or training
 - o Compliance audits
- Monitoring may take place at Lean Tech's discretion on a monthly, quarterly, annual basis, in response to incidents, or after significant changes.

Lean Tech will obtain notify ask for approval from SAMA when planning to outsource services.